

# REST API Documentation

---

Base URL: `http://localhost:3001/api`

## Authentication

Protected endpoints require:

```
Authorization: Bearer <token>
```

## OTP behavior

By default, login starts an OTP session. For load tests or local scenarios where login should be phone-number only, set:

```
DISABLE_OTP=true
```

With `DISABLE_OTP=true`, `POST /auth/login` returns a JWT token directly from this request body:

```
{ "phoneNumber": "+6281234567892" }
```

## Auth Endpoints

### `POST /auth/login`

Request:

```
{ "phoneNumber": "+6281234567892" }
```

Default OTP response:

```
{
  "sessionId": "8f1f2f20-5a28-4a61-a54b-4a17e09cfa40",
  "expires": 1778123456789
}
```

Response when `DISABLE_OTP=true`:

```
{
  "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9...",
  "user": {
    "id": 3,
    "fullName": "Budi Santoso",
    "phoneNumber": "+6281234567892",
    "role": "tenant",
    "isVerifiedTenant": true,
    "unitNumber": "1703",
    "createdAt": "2026-01-21T00:00:00.000Z",
    "updatedAt": "2026-01-21T00:00:00.000Z"
  }
}
```

### POST /auth/otp

Verify an OTP session and receive a JWT.

```
{
  "sessionId": "8f1f2f20-5a28-4a61-a54b-4a17e09cfa40",
  "otp": "1234"
}
```

Response:

```
{
  "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9...",
  "user": {
    "id": 3,
    "fullName": "Budi Santoso",
    "phoneNumber": "+6281234567892",
    "role": "tenant",
    "isVerifiedTenant": true,
    "unitNumber": "1703",
    "createdAt": "2026-01-21T00:00:00.000Z",
    "updatedAt": "2026-01-21T00:00:00.000Z"
  }
}
```

### POST /auth/resend

Replace an existing OTP session with a new one.

```
{ "sessionId": "8f1f2f20-5a28-4a61-a54b-4a17e09cfa40" }
```

Response:

```
{
  "phoneNumber": "+6281234567892",
  "sessionId": "b24a4c35-a318-4e5b-b418-7ea8a9ff2db7",
  "expires": 1778123756789
}
```

### GET /auth/me

Protected. Returns the authenticated user.

## Facilities

### GET /facilities

Public. Returns active facilities.

### GET /facilities/:id

Public. Returns one facility.

### GET /facilities/:id/slots?date=YYYY-MM-DD

Public. Returns hourly availability for one facility and date.

```
{
  "facilityId": 1,
  "date": "2026-01-22T00:00:00.000Z",
  "slots": [
    { "startTime": "06:00:00", "endTime": "07:00:00", "isAvailable": true }
  ]
}
```

### POST /facilities

Admin or super admin only. Creates a facility.

```
{
  "name": "Swimming Pool",
  "description": "Olympic-size indoor pool",
  "pricePerHour": 75000,
  "openTime": "06:00:00",
  "closeTime": "21:00:00",
  "isActive": true
}
```

## PATCH /facilities/:id

Admin or super admin only. Updates provided fields.

```
{
  "pricePerHour": 80000,
  "isActive": false
}
```

## DELETE /facilities/:id

Admin or super admin only. Permanently deletes a facility. Returns 204 No Content.

# Bookings

## GET /bookings

Admin or super admin only. Returns all bookings.

## POST /bookings

Protected. Creates a booking.

```
{
  "userId": 3,
  "facilityId": 1,
  "bookingDate": "2026-01-22",
  "startTime": "14:00:00",
  "endTime": "15:00:00"
}
```

Response:

```
{
  "id": 301,
  "userId": 3,
  "facilityId": 1,
  "bookingDate": "2026-01-22T00:00:00.000Z",
  "startTime": "14:00:00",
  "endTime": "15:00:00",
  "status": "pending",
  "totalPrice": 50000,
  "createdAt": "2026-01-21T00:00:00.000Z",
  "updatedAt": "2026-01-21T00:00:00.000Z"
}
```

## GET /bookings/:id

Protected. Returns a flat booking.

**GET** /bookings/:id/details

Protected. Returns a booking with nested **user** and **facility**.

**PUT** /bookings/:id/confirm

Protected. Confirms a pending booking.

**DELETE** /bookings/:id

Protected. Cancels a booking by setting **status** to **cancelled**.

**DELETE** /bookings/:id/hard

Admin or super admin only. Permanently deletes a booking. Returns **204 No Content**.

## Users

**GET** /users

Admin or super admin only. Returns all users.

**POST** /users

Admin or super admin only. Creates a user.

```
{
  "fullName": "Siti Rahayu",
  "phoneNumber": "+6289876543210",
  "role": "tenant",
  "isVerifiedTenant": true,
  "unitNumber": "0802"
}
```

**GET** /users/:id

Protected. Returns one user.

**GET** /users/:id/bookings?limit=10&offset=0

Protected. Returns paginated bookings with nested user and facility data. **limit** defaults to **10**; **offset** defaults to **0**.

**GET** /users/:id/dashboard?limit=10&offset=0

Protected. Returns user details, paginated bookings, **bookingCountToday**, **upcomingBookings**, and **totalSpent**.

## PATCH /users/:id

Admin or super admin only. Updates provided fields.

```
{
  "isVerifiedTenant": true,
  "unitNumber": "1203"
}
```

## DELETE /users/:id

Admin or super admin only. Permanently deletes a user. Returns 204 No Content.

## Error Responses

```
{
  "error": "ValidationError",
  "message": "Validation failed",
  "code": "VALIDATION_ERROR",
  "fields": {
    "phoneNumber": "Phone number must contain only digits and optional + prefix"
  }
}
```

Common statuses: 200, 201, 204, 400, 401, 403, 404, 409, 500.